

EDICIÓN PÚBLICA

ODRE PQC v0.2.9

Public Technical Whitepaper Rev.2

Edición en español

2 de septiembre de 2026

Contenido

1. Resumen ejecutivo
2. Propósito y arquitectura
3. Perfil criptográfico y contrato de seguridad
4. Modelo de amenazas y límites de confianza
5. Evidencia de verificación y auditoría
6. Resultados multiplataforma
7. Separación de la capa comercial
8. Despliegue y límite de divulgación
9. Conclusión

Document identity

Product	ODRE PQC
Version	0.2.9
Artifact	odre_pqc-0.2.9-py3-none-any.whl
Wheel SHA-256	A8AFA10EE0AFACEF1C0FAF55FF07B96C722920E5AEE8692F6F026E804F028697
Evidence manifest SHA-256	4AF2C88FDEA0CB1FB030E4AB6D5B41394CC52397664364233482E3EC14945F3B
Cryptographic runtime	OpenSSL 3.5.8 / ML-KEM-768 / ML-DSA-65
Verified platforms	Windows Server 2022 AMD64; Ubuntu 24.04.4 LTS AMD64
Core audit verdict	ODRE_PQC_v0.2.9_FULL_DEVSEC_AUDIT_PASS

Resumen ejecutivo

ODRE PQC es un límite de seguridad poscuántica integrado en la aplicación para rutas FastAPI protegidas. Combina gestión del runtime criptográfico, sesiones autenticadas, secuenciación estricta, resistencia a replay, semántica protegida de solicitudes y respuestas, confianza en artefactos nativos, control de ciclo de vida y aplicación fail-closed tras una superficie de integración pequeña.

La versión 0.2.9 es el artefacto multiplataforma sellado identificado por el SHA-256 de este documento. La misma Wheel superó una auditoría de seguridad de desarrollo nueva en Windows Server 2022 AMD64 y Ubuntu 24.04.4 LTS AMD64. No quedó ningún hallazgo confirmado Critical, High o Medium dentro del alcance ejecutado.

Este documento informa evidencia, no seguridad absoluta. PASS se aplica solo al artefacto, plataformas, configuraciones, modelos de amenaza y pruebas indicados. El despliegue en producción sigue siendo una decisión separada y controlada por el operador.

Propósito y arquitectura

ODRE PQC protege rutas seleccionadas. No sustituye TLS, identidad, autorización, codificación segura, hardening, parches, copias de seguridad ni monitorización. Los handlers protegidos se ejecutan solo después de que el límite PQC acepte la solicitud.

El modelo público es pequeño: inicializar, diagnosticar, verificar, llamar `install(app)`, iniciar el servidor y consultar estado autenticado. El contrato de red es `odre-pqc/3`. Las diferencias de plataforma permanecen en adaptadores y bundles nativos incluidos en una sola Wheel Python.

```
Flujo: odre-pqc init -> doctor -> verify -> from odre_pqc import install; install(app) -> server start -> odre-pqc status
```

Perfil criptográfico y contrato de seguridad

El runtime auditado se identifica como OpenSSL 3.5.8 (OpenSSL_version_num 0x30500080). Las pruebas reales ML-KEM-768, ML-DSA-65 y el handshake híbrido pasaron en ambos sistemas objetivo.

ODRE PQC no cambia silenciosamente a protección classical-only en rutas protegidas. Si proveedor, claves, sesión, replay, confianza nativa o salud del runtime no cumplen el contrato, la ruta se bloquea antes de ejecutar lógica de negocio.

La semántica observada por el handler coincide con la semántica interna autenticada. Estado, headers ordenados, cookies y body de la respuesta permanecen dentro del frame protegido. Replay, rollback, gap, mismatch y ambigüedad cross-route/cross-session se rechazan fail-closed.

Modelo de amenazas y límites de confianza

La auditoría ejerció manipulación de red, replay, concurrencia, entradas malformadas y sobredimensionadas, confusión semántica, fuga de metadatos, crash/restart, sustitución del sistema de archivos, symlink/reparse, inyección de dependencias/proveedor y carreras de ciclo de vida.

Se presupone que sistema operativo, CPU, runtime Python y administrador autorizado no están totalmente comprometidos. No se afirma protección frente a kernel malicioso, administrador irrestricto, extracción física, lógica comprometida tras admisión, DoS no probado ni futuros avances criptoanalíticos.

Evidencia de verificación y auditoría

La Wheel sellada se instaló desde una copia nueva con bloqueo de hash. Los hashes inicial y final coincidieron. No se reutilizaron informes previos como evidencia PASS y los bytes del producto no cambiaron durante la auditoría.

La revisión estática cubrió 38 archivos Python y 7.160 líneas, metadata, RECORD, soporte de plataforma y manifests/archives nativos. RECORD pasó 45/45. Consultas nuevas sobre 19 dependencias devolvieron cero errores y cero registros de vulnerabilidad en ese momento.

Metric	Windows	Ubuntu
Platform verdict	PASS	PASS
Replay-race requests	1,280	2,880
Double handler execution	0	0
Native load attempts	3,000	-
Atomic replacements observed	1,062	-
Junction create/remove cycles	3,000	-
Late-promotion parent swaps	-	600 / 600
Untrusted load / object misbinding	0	0
Unresolved Critical / High / Medium	0 / 0 / 0	0 / 0 / 0

Resultados multiplataforma

Windows cubrió instalación offline, init, protección de segundo init, doctor, verify, estado autenticado, transición de sesión, replay race, binding semántico, ACL, vida de recursos, tamper, recuperación de crash y stress de carga nativa.

Ubuntu cubrió init, diagnóstico negativo, PQC real, replay race, fuzz de admisión, entradas inválidas y grandes, formas HTTP smuggling, secreto de respuesta, WebSocket fail-closed, confianza de objeto nativo, init concurrente, colisión de workers y reinicio normal/forzado.

Separación de la capa comercial

Licencia, pago, descarga, Trial y monitorización forman un control plane comercial y no el Core criptográfico sellado v0.2.9. El código comercial pasó 102/102 pruebas aisladas; 60/60 regresiones JigumON pasaron. El ciclo aislado upgrade-downgrade-upgrade también pasó.

Esto no afirma despliegue en producción. PostgreSQL, PayPal live, SMTP, secretos de producción, proxy confiable, helper de cliente desplegado y enforcement end-to-end no estaban completados. El veredicto es código y pruebas aisladas PASS; producción NOT READY.

Despliegue y límite de divulgación

Entornos verificados: Windows Server 2022 AMD64 con CPython 3.12.10 y Ubuntu 24.04.4 LTS AMD64 con CPython 3.12.3. Otras distribuciones, Ubuntu 22.04, Debian 12 y ARM64 no se presentan como verificados por esta evidencia.

Esta edición no publica claves privadas, credenciales, source del producto, bytes de Wheel, binarios nativos, harnesses ni datos de clientes. Los informes internos siguen privados. La cifra de aproximadamente 179,4 millones de fuzz, sin informe fuente independiente localizado, no se afirma aquí.

Conclusión

ODRE PQC v0.2.9 ofrece una integración compacta respaldada por un contrato fail-closed estricto, algoritmos poscuánticos reales y una identidad sellada multiplataforma. La evidencia disponible respalda el resultado de auditoría indicado dentro de su alcance definido.

La seguridad es un proceso continuo. Los operadores deben preservar la identidad del artefacto, seguir la guía soportada, mantener host y aplicación y tratar cambios futuros como nuevas obligaciones de evidencia.

Libro blanco técnico público Rev.2 - separación explícita entre Core y Commercial.